
La raccolta illecita di dati tramite *form* online

*Profili giuridici e tecnici della raccolta di dati personali
mediante moduli web inadeguatamente predisposti*

Informatica Forense

Martino Papa, Alessio Minati

Anno Accademico 2025/2026

1. Introduzione: la raccolta di dati nel contesto digitale

L'era digitale ha radicalmente mutato le modalità con cui soggetti pubblici e privati entrano in contatto con i propri utenti. L'utilizzo di *form* online (ossia di moduli web strutturati per la raccolta di informazioni) è diventato prassi ordinaria in ogni settore. Tali strumenti consentono di acquisire, con semplicità e a costo pressoché nullo, una mole considerevole di dati personali.

Proprio questa facilità di accesso ai dati costituisce, tuttavia, il principale fattore di rischio. L'importanza dei dati personali nell'epoca attuale risiede nel fatto che essi veicolano la nostra immagine nella rete; il diritto alla protezione dei dati personali si configura pertanto non soltanto come espressione del diritto alla riservatezza, ma anche come vera e propria espressione del *diritto all'autodeterminazione informativa* (Pietropaoli 2022, p. 38, § 2.7).

Quando il *form* online viene predisposto in assenza di un'adeguata base giuridica, senza un'informativa chiara, senza la distinzione tra dati ordinari e dati particolari (ovvero dati *sensibili*), oppure in violazione dei principi tecnici di sicurezza, si realizzano le condizioni per una pluralità di illeciti, tanto amministrativi quanto penali, che saranno esaminati nel presente documento.

La disciplina di riferimento è costituita principalmente dal Regolamento (UE) 2016/679 (*General Data Protection Regulation*, d'ora in poi GDPR) (*Regolamento (UE) 2016/679 del Parlamento europeo e del Consiglio, del 27 aprile 2016, relativo alla protezione delle persone fisiche con riguardo al trattamento dei dati personali, nonché alla libera circolazione di tali dati (General Data Protection Regulation – GDPR) 2016*) e dal Decreto Legislativo 30 giugno 2003, n. 196 (*Codice in materia di protezione dei dati personali*, d'ora in poi Codice Privacy), come modificato dal D.Lgs. 10 agosto 2018, n. 101 (*Decreto legislativo 30 giugno 2003, n. 196 – Codice in materia di protezione dei dati personali 2003; Decreto legislativo 10 agosto 2018, n. 101 – Disposizioni per l'adeguamento della normativa nazionale alle disposizioni del Regolamento (UE) 2016/679 2018*). A livello di diritto fondamentale, vengono in rilievo l'art. 8 della Carta dei Diritti Fondamentali dell'Unione Europea (*Carta dei diritti fondamentali dell'Unione europea 2012*) e l'art. 8 della Convenzione Europea per la salvaguardia dei Diritti dell'Uomo e delle Libertà Fondamentali (CEDU) (*Convenzione per la salvaguardia dei diritti dell'uomo e delle libertà fondamentali (CEDU) 1950*).

2. Il quadro normativo

2.1. La distinzione tra dati personali ordinari e dati particolari (sensibili)

Preliminare a ogni valutazione giuridica è la corretta qualificazione del tipo di dato raccolto tramite il *form*. L'art. 4, n. 1 del GDPR definisce **dato personale** «qualsiasi informazione riguardante una persona fisica identificata o identificabile».

Il legislatore europeo distingue poi una categoria di dati che richiedono una tutela rafforzata, denominati **dati particolari** (art. 9 GDPR) o, nel linguaggio del Codice Privacy, **dati sensibili**. Appartengono a tale categoria:

- dati che rivelano l'origine razziale o etnica;
- dati relativi alle opinioni politiche, alle convinzioni religiose o filosofiche;
- dati relativi all'appartenenza sindacale;
- dati genetici e dati biometrici (se diretti a identificare univocamente una persona);
- dati relativi alla salute;
- dati relativi alla vita sessuale o all'orientamento sessuale.

L'art. 9, par. 1 GDPR stabilisce un divieto generale di trattamento di tali dati, salve le eccezioni tassativamente elencate al par. 2 (consenso esplicito, obblighi di diritto del lavoro, interessi vitali, ecc.). Ciò implica che un *form* web che, anche solo facoltativamente, contenga campi relativi a dati particolari senza un'esplicita base giuridica ai sensi dell'art. 9 par. 2 è da considerarsi già, di per sé, in violazione del Regolamento.

Art. 9 GDPR – Trattamento di categorie particolari di dati personali (sintesi)

Par. 1: “È vietato trattare dati personali che rivelino l'origine razziale o etnica, le opinioni politiche, le convinzioni religiose o filosofiche, o l'appartenenza sindacale, nonché trattare dati genetici, dati biometrici intesi ad identificare in modo univoco una persona fisica, dati relativi alla salute o alla vita sessuale o all'orientamento sessuale della persona.”

Par. 2: Il divieto non si applica nei casi ivi tassativamente previsti, tra cui il *consenso esplicito* dell'interessato (lett. a).

Fonte: Regolamento (UE) 2016/679, art. 9 (Regolamento (UE) 2016/679 del Parlamento europeo e del Consiglio, del 27 aprile 2016, relativo alla protezione delle persone fisiche con riguardo al trattamento dei dati personali, nonché alla libera circolazione di tali dati (General Data Protection Regulation – GDPR) 2016).

2.2. Il profilo civilistico

2.2.1. I principi del GDPR applicabili alla raccolta tramite form

L'art. 5 del GDPR definisce i principi essenziali per il trattamento dei dati, che devono essere rispettati sin dalla fase di creazione di qualsiasi *form* online. In particolare:

- a) **Liceità, correttezza e trasparenza** (art. 5, par. 1, lett. a): ogni raccolta deve fondarsi su una base giuridica valida (consenso, contratto, obbligo legale, interessi vitali, interesse pubblico o legittimo interesse del titolare);
- b) **Limitazione della finalità** (art. 5, par. 1, lett. b): i dati raccolti tramite il modulo possono essere trattati esclusivamente per le finalità determinate, esplicite e legittime indicate nell'informativa;
- c) **Minimizzazione dei dati** (art. 5, par. 1, lett. c): il *form* deve raccogliere soltanto i dati *adeguati, pertinenti e limitati* a quanto necessario rispetto alle finalità perseguite; qualsiasi campo superfluo integra una violazione del Regolamento;
- d) **Esattezza** (art. 5, par. 1, lett. d): il titolare deve adottare misure ragionevoli per garantire la correttezza dei dati raccolti;
- e) **Limitazione della conservazione** (art. 5, par. 1, lett. e): i dati devono essere conservati in una forma che consenta l'identificazione degli interessati per un periodo non superiore al conseguimento delle finalità per le quali sono trattati;
- f) **Integrità e riservatezza** (art. 5, par. 1, lett. f): il *form* deve essere tecnicamente protetto, con connessione cifrata (protocollo HTTPS/TLS) e misure di sicurezza adeguate.

2.2.2. L'obbligo di informativa e il consenso

L'art. 13 GDPR impone al titolare del trattamento di fornire all'interessato, al momento della raccolta dei dati, una serie di informazioni in forma concisa, trasparente e intellegibile. Un *form* online sprovvisto di informativa, oppure che rimandi a un testo generico e incomprensibile, è in violazione di tale obbligo.

Qualora la raccolta dei dati si basi sul **consenso** dell'utente, non essendo strettamente obbligatoria per altri motivi (art. 6, par. 1, lett. a), l'art. 7 del GDPR stabilisce che tale consenso debba essere:

- **libero**: l'accesso al servizio non deve essere condizionato alla prestazione del consenso per finalità non necessarie;

- **specifico**: un unico checkbox che raggruppi più finalità non soddisfa il requisito;
- **informato**: deve riferirsi a un'informativa adeguata;
- **inequivocabile**: le caselle pre-spuntate (*pre-ticked boxes*) non integrano un consenso valido.

2.2.3. Responsabilità civile del titolare del trattamento

L'art. 82 GDPR sancisce il diritto di ogni interessato che abbia subito un danno — materiale o immateriale — in conseguenza di una violazione del Regolamento, di ottenere il risarcimento dal titolare o dal responsabile del trattamento. Il titolare è esonerato da responsabilità soltanto se dimostri che l'evento dannoso non gli è in alcun modo imputabile: si tratta di una *presunzione di responsabilità* con onere della prova invertito a carico del titolare.

Le sanzioni amministrative pecuniarie, irrogate dal Garante per la protezione dei dati personali, possono raggiungere, ai sensi dell'art. 83 GDPR:

- fino a **10 milioni di euro** o, per le imprese, il **2%** del fatturato mondiale annuo, per le violazioni di cui al par. 4 (es. violazione delle condizioni del consenso, mancata informativa);
- fino a **20 milioni di euro** o il **4%** del fatturato mondiale annuo, per le violazioni di cui al par. 5 (es. violazione dei principi di base, trattamento di dati particolari senza base giuridica).

2.3. Il profilo penalistico

2.3.1. Il trattamento illecito di dati personali (art. 167 Codice Privacy)

Per fronteggiare le violazioni della sfera della riservatezza nell'ambito digitale, nel nostro ordinamento sono state introdotte alcune norme penali, inserite non nel Codice penale ma nel d.lgs. 196/2003 (Codice privacy) (Pietropaoli 2022, p. 38, § 2.7).

L'art. 167 del Codice Privacy, nella formulazione successiva all'adeguamento al GDPR operato dal D.Lgs. 101/2018, punisce con la reclusione da **sei mesi a un anno e sei mesi** chiunque, al fine di trarne per sé o per altri profitto ovvero al fine di recare ad altri un danno, proceda al trattamento di dati personali in violazione delle disposizioni di cui agli artt. 123, 126, 129 e 130 del medesimo decreto, nonché in violazione delle misure di garanzia di cui all'art. 2-*quinqüiesdecies*, laddove ne consegua una lesione.

La pena è aumentata a **uno a tre anni** qualora il fatto riguardi dati sensibili.

Art. 167 D.Lgs. 196/2003 – Trattamento illecito di dati (sintesi)

“1. Salvo che il fatto costituisca più grave reato, chiunque, al fine di trarne per sé o per altri profitto ovvero al fine di recare ad altri un danno, procede al trattamento di dati personali in violazione di quanto disposto [...] è punito, se dal fatto deriva nocumento, con la reclusione da sei mesi a un anno e sei mesi.

2. Se il fatto di cui al comma 1 riguarda dati genetici, biometrici o relativi alla salute, alla vita sessuale, all’orientamento sessuale o alle opinioni, [...] la pena è la reclusione da uno a tre anni.”

Fonte: D.Lgs. 30 giugno 2003, n. 196, art. 167 (Decreto legislativo 30 giugno 2003, n. 196 – Codice in materia di protezione dei dati personali 2003).

Perché si configuri questo reato, la giurisprudenza ha stabilito che non è strettamente necessario un danno economico: è sufficiente anche un danno di natura morale. Inoltre, il vantaggio illecito perseguito dal colpevole può consistere in un qualsiasi tipo di beneficio, anche non monetario.

2.3.2. La comunicazione e diffusione illecita di dati personali su larga scala (art. 167-bis)

L’art. 167-bis del Codice Privacy (introdotto dal D.Lgs. 101/2018) punisce con la reclusione da **uno a sei anni** chiunque comunichi o diffonda dati personali oggetto di trattamento su larga scala, in violazione delle disposizioni del GDPR. La norma si applica con particolare intensità nel caso in cui i dati raccolti tramite *form* vengano ceduti a terzi o pubblicati senza autorizzazione, configurando un cosiddetto **data breach deliberato**.

Art. 167-bis D.Lgs. 196/2003 – Comunicazione e diffusione illecita di dati su larga scala (sintesi)

“1. Salvo che il fatto costituisca più grave reato, chiunque comunica o diffonde, al fine di trarne profitto per sé o altri ovvero al fine di arrecare danno, un archivio automatizzato o una parte sostanziale di esso contenente dati personali oggetto di trattamento su larga scala, in violazione degli articoli 2-ter, 2-sexies e 2-octies, è punito con la reclusione da uno a sei anni.”

Fonte: D.Lgs. 30 giugno 2003, n. 196, art. 167-bis (Decreto legislativo 30 giugno 2003, n. 196 – Codice in materia di protezione dei dati personali 2003).

2.3.3. L’acquisizione fraudolenta di dati personali su larga scala (art. 167-ter)

L’art. 167-ter del Codice Privacy punisce con la reclusione da **uno a quattro anni** chiunque, al fine di trarne profitto per sé o per altri ovvero per recare danno, acquisisca fraudolentemente dati personali oggetto di trattamento su larga scala. Tale fattispecie

riguarda, tra l'altro, la predisposizione di *form* ingannevoli (c.d. *dark patterns*) che inducano l'utente a fornire dati personali in modo che non è consapevole o che non ha inteso.

Art. 167-ter D.Lgs. 196/2003 – Acquisizione fraudolenta di dati su larga scala (sintesi)

“1. Salvo che il fatto costituisca più grave reato, chiunque, al fine di trarne profitto per sé o altri ovvero di arrecare danno, acquisisca con mezzi fraudolenti un archivio automatizzato o una parte sostanziale di esso contenente dati personali oggetto di trattamento su larga scala è punito con la reclusione da uno a quattro anni.”

Fonte: D.Lgs. 30 giugno 2003, n. 196, art. 167-ter (Decreto legislativo 30 giugno 2003, n. 196 – Codice in materia di protezione dei dati personali 2003).

3. Casi pratici e giurisprudenza

3.1. Garante Privacy – Sanzione per form web senza adeguata informativa (2021)

Un ente pubblico aveva predisposto sul proprio sito web un modulo di contatto (*form*) che raccoglieva nome, cognome, indirizzo e-mail e numero di telefono degli utenti, senza che nella pagina fosse presente alcuna informativa adeguata ai sensi dell'art. 13 GDPR. Il Garante ha accertato la violazione dei principi di liceità, correttezza e trasparenza (art. 5, par. 1, lett. a GDPR) e ha irrogato una sanzione pecuniaria amministrativa, disponendo altresì la rettifica del *form*.

Fonte: (Garante per la protezione dei dati personali 2021).

Il caso illustra la fattispecie più frequente: il titolare del trattamento non predispone alcuna informativa visibile nella pagina che ospita il modulo, o la inserisce in un link oscuro nel *footer* del sito, ritenendo erroneamente di assolvere così all'obbligo informativo. Tale prassi non soddisfa il requisito della *trasparenza* sancito dall'art. 12 GDPR, il quale impone che le informazioni siano fornite in forma concisa, facilmente accessibile e comprensibile.

3.2. Garante Privacy – Trattamento illecito di dati particolari tramite form (2022)

Un'azienda privata aveva inserito nel proprio *form* di candidatura online campi contrassegnati come *facoltativi* relativi allo stato di salute e all'eventuale appartenenza sindacale dei candidati. Il Garante ha rilevato che, ai sensi dell'art. 9 GDPR, il trattamento di dati particolari non può essere fondato esclusivamente sulla facoltatività del campo, ma richiede un'esplicita e valida base giuridica tra quelle elencate all'art. 9, par. 2. L'ente è stato sanzionato per violazione degli artt. 5, 6 e 9 GDPR.

Fonte: (Garante per la protezione dei dati personali 2022).

Tale pronuncia evidenzia un equivoco diffuso: la *facoltatività* di un campo non esclude la necessità di una base giuridica per il trattamento dei dati ivi inseriti. Se il campo è facoltativo ma raccoglie dati particolari, occorre comunque che il consenso sia esplicito (art. 9, par. 2, lett. a GDPR), granulare e separato dagli altri consensi.

3.3. Corte di Cassazione penale – Trattamento illecito di dati a fini di profitto (2019)

La Suprema Corte ha confermato la configurabilità del reato di cui all'art. 167 del Codice Privacy in capo a un operatore che aveva sistematicamente raccolto, tramite un servizio web, dati personali degli utenti senza il loro consenso e li aveva successivamente ceduti a terzi a fini commerciali. La Corte ha precisato che il *fine di profitto* richiesto dalla norma è integrato anche dalla sola prospettiva di un vantaggio economico indiretto, e che il *nocumento* può consistere anche in un danno non patrimoniale, quale la perdita del controllo sui propri dati personali.

Fonte: (Corte di Cassazione, Sezione II penale 2019).

Questa pronuncia è particolarmente significativa per i moduli web destinati alla profilazione commerciale. Essa evidenzia come la raccolta di dati in assenza di un'idonea informativa e di un valido consenso, seguita dalla loro cessione a terzi, sia sufficiente a configurare il reato di trattamento illecito, a prescindere dal guadagno effettivamente ottenuto.

3.4. Corte di Cassazione civile – Risarcimento del danno per trattamento illecito (2023)

La Suprema Corte ha confermato la condanna al risarcimento del danno non patrimoniale in favore di un utente i cui dati personali erano stati raccolti tramite un modulo web privo di adeguata informativa e, successivamente, comunicati a terzi non autorizzati. I giudici hanno richiamato l'art. 82 GDPR e ribadito che spetta al titolare del trattamento fornire la prova liberatoria dell'assenza di colpa. Il mero fatto che i dati siano stati trattati in violazione del GDPR costituisce presupposto sufficiente per riconoscere il danno non patrimoniale, senza che l'interessato debba dimostrare un pregiudizio ulteriore concreto.

Fonte: (Corte di Cassazione, Sezione I civile 2023).

La decisione riveste un'importanza fondamentale sul piano della responsabilità civile del titolare del trattamento. L'inversione dell'onere della prova e il riconoscimento del danno non patrimoniale legato alla semplice perdita di controllo sui propri dati personali rendono l'azione risarcitoria un rischio concreto per chiunque gestisca moduli web non conformi. La conformità del *form* non rappresenta quindi solo una tutela contro le sanzioni del Garante, ma uno scudo indispensabile contro le richieste di risarcimento dirette degli utenti.

4. Conclusioni

L'analisi svolta consente di formulare le seguenti considerazioni conclusive.

In primo luogo, la predisposizione di un *form* online per la raccolta di dati personali non è un'operazione neutra sul piano giuridico, ma implica l'assunzione di precisi obblighi di legge in capo al titolare del trattamento, la cui violazione espone a conseguenze che spaziano dalla sanzione amministrativa pecuniaria fino alla responsabilità penale.

In secondo luogo, la distinzione tra dati personali ordinari e dati particolari (sensibili) è di importanza cruciale: l'inserimento nel *form*, anche solo facoltativamente, di campi relativi alla salute, all'orientamento sessuale, alle opinioni politiche o ad altri elementi elencati nell'art. 9 GDPR richiede una base giuridica rafforzata e misure di sicurezza tecnicamente adeguate.

Da un punto di vista operativo, chiunque intenda predisporre un *form* online per la raccolta di dati personali deve, come *minima misura*:

1. definire e documentare le finalità del trattamento;
2. identificare la base giuridica applicabile;
3. predisporre e rendere visibile un'informativa completa ex art. 13 GDPR;
4. raccogliere soltanto i dati strettamente necessari (*data minimisation*);
5. adottare misure tecniche di sicurezza adeguate (cifatura, HTTPS, ecc.);
6. in caso di dati particolari, acquisire un consenso esplicito e separato.

La mancata osservanza anche di una sola di queste prescrizioni può integrare, a seconda dei casi, un illecito amministrativo o un illecito penale, con le gravi conseguenze patrimoniali e reputazionali che ne derivano.

Riferimenti normativi e bibliografici

- Carta dei diritti fondamentali dell'Unione europea* (2012). Gazzetta Ufficiale dell'Unione Europea, C 326, pp. 391–407. Art. 8 – Protezione dei dati di carattere personale; Art. 7 – Rispetto della vita privata e della vita familiare.
- Convenzione per la salvaguardia dei diritti dell'uomo e delle libertà fondamentali (CEDU)* (1950). Roma, 4 novembre 1950. Art. 8 – Diritto al rispetto della vita privata e familiare.
- Corte di Cassazione, Sezione I civile (2023). *Sentenza 10 gennaio 2023, n. 407*. Trattamento illecito di dati personali raccolti tramite form web privo di adeguata informativa: risarcimento del danno non patrimoniale.
- Corte di Cassazione, Sezione II penale (2019). *Sentenza 15 gennaio 2019, n. 1285*. Trattamento illecito di dati personali (art. 167 D.Lgs. 196/2003): configurabilità del reato in caso di raccolta di dati senza consenso a scopo di profitto.
- Decreto legislativo 10 agosto 2018, n. 101 – Disposizioni per l'adeguamento della normativa nazionale alle disposizioni del Regolamento (UE) 2016/679* (2018). Gazzetta Ufficiale della Repubblica Italiana, n. 205.
- Decreto legislativo 30 giugno 2003, n. 196 – Codice in materia di protezione dei dati personali* (2003). Gazzetta Ufficiale della Repubblica Italiana, n. 174. Modificato dal D.Lgs. 10 agosto 2018, n. 101 per l'adeguamento al GDPR.
- Garante per la protezione dei dati personali (2021). *Provvedimento del 29 aprile 2021 – Sanzione per raccolta di dati tramite form online senza adeguata informativa e senza valido consenso*. Newsletter del Garante, n. 479. Sito web di un ente pubblico sanzionato per carente informativa ex art. 13 GDPR nella raccolta di dati tramite modulo di contatto online.
- (2022). *Provvedimento del 15 settembre 2022 – Sanzione per trattamento illecito di dati speciali raccolti tramite form online*. Registro dei provvedimenti del Garante. Il titolare del trattamento aveva inserito in un form web campi facoltativi relativi a dati di salute senza una valida base giuridica ex art. 9 GDPR.
- Pietropaoli, Stefano (2022). *Informatica criminale. Diritto e sicurezza nell'era digitale*. Torino: G. Giappichelli Editore. ISBN: 978-88-921-4451-4.
- Regolamento (UE) 2016/679 del Parlamento europeo e del Consiglio, del 27 aprile 2016, relativo alla protezione delle persone fisiche con riguardo al trattamento dei dati personali, nonché alla libera circolazione di tali dati (General Data Protection Regulation – GDPR)* (2016). Gazzetta Ufficiale dell'Unione Europea, L 119, pp. 1–88. Entrato in vigore il 25 maggio 2018.